

資訊安全期末考

問答題 (100%,每題 7 分,共 15 題)

1. 認證訊息主要可分為哪三個型式？

Answer：

型式一： 你所知道的事物 (Something You Know)，這是一個文字字串，必須記住；認證時，提供原始字串並輸入認證系統。本認證方法較為簡單，但也可能不小心洩漏此字串。若他人也知道此認證字串，即可冒用你的身分進入系統。例如，密碼 (Password；或稱通行碼)、 通行語 (Password Phase)、你喜歡的顏色等，都可以作為系統認證資訊。

通行語之使用，如同密碼一般，可以採用比較長的句子，以提高安全性。例如，使用『 This is a pass phrase AAA 』作為通行語，可以降低被猜中或破解的機率。

型式二： 你所擁有的事物 (Something You Have)，這是一個實體的設施，事先發送此設施給使用者。在認證時，使用者需要攜帶此設施接受認證。基本上，此認證設施不容易偽造，但有遺失的可能。

型式三：你具有的特徵 (Something You Are)，個人生理的或物理的特徵。例如，指紋、聲音、虹膜式樣、視網膜式樣、臉形、手形等。指紋是指手指末端指腹上由凹凸的皮膚所形成的紋路，也可指這些紋路在物體上印下的印痕。不同的人擁有不相同的指紋，每個人的指紋也是獨一無二的。虹膜辨識技術是利用眼球前圍繞瞳孔旁呈現的一層生理薄膜，每個人都有不同的紋理。視網膜辨識技術是利用眼球後部血管的分佈作為特徵點。

2. 技術型存取控制是什麼？

Answer：

從技術層面進行之存取控制，以管理系統資源，防止非法存取資源，技術是指邏輯性技術。例如圖 9-12 所示，密碼登入系統、IC 卡登入系統、防火牆、入侵偵測系統等。

3. 什麼是分散式阻斷服務攻擊(DDoS) ？

Answer: DDoS 是 DoS 的一種，攻擊的模式不是一對一，而是以多對一的方式，同時對一個目標發動攻擊，而這些發動攻擊的節點，是已經被入侵而不自知的受控制電腦。由於這種攻擊方式以遠端遙控方式，因此不僅難以防範，追查更是不易。

圖 9-12 密碼登入系統

4. 舉例說明 SQL 語法？

Answer: 關聯式資料庫所用之術語與在 SQL 語法上的術語名稱有一些差異 (表 8-2)，SQL 是實現關聯式存取介面的語法，其間差異對照如下：

表 8-2 關聯式資料庫與 SQL 語法術語對照表

關聯式資料庫	SQL 語法
關聯表 (Relation)	資料表 (Table)
屬性 (Attribute)	欄位 (Field)
值組 (Tuple)	記錄 (Record)

5. 內部稽核有哪三個目標？

Answer：內部稽核用來幫助偵測可疑的行為，有下列三個目標：

- 確保所有的運作均能按照既定的安全政策執行。
- 確保所有資料的存取都要經過授權。
- 確保所有資料的正確性。

6. 何謂軟體能力成熟度模式？

Answer：

軟體能力成熟度模式 (Software Capacity Maturity Model Integration) 是美國卡內基美隆大學 (Carnegie Mellon University) 的『軟體工程學院』 (Software Engineering Institute) 所發展的一套具備組織性的系統工程和軟體工程整合模式。軟體能力成熟度模式可協助整合傳統上分開的企業組織功能，並訂立流程改善目標及優先順序，同時為欲實行最佳流程的公司提供指引及評估。軟體能力成熟度模式與軟體發展週期可以並存，它是提供軟體發展之整合平台。

7. 何謂服務等級合約 (Service Level Agreements ; SLA) ?

Answer :

資訊系統上線營運後，系統開發廠商如無法提供後續的服務，將造成業者或顧客重大損失。為了確保後續的服務品質，需要訂立服務等級合約 (Service Level Agreements ; SLA)，服務等級合約是為維持服務品質，所立下之服務條約，一種雙方(客戶-業者或業者-業者)所協商出的一種契約服務。系統提供者與顧客之間雙方同意的約定，裡面定義了服務目標及雙方的預期及責任。